

1. Lame — HackTheBox

Lame

🖨️ IP / Host: 10.10.10.3

📅 Fecha: 17/08/2026

👤 User Flag: 92c5a1b32d04e5781a2f4c6e8b1d3fa1

👑 Root Flag: f61e88d098e21a7b45c38902fae8b942

HackTheBox

EASY

Linux

Samba

RCE

CVE-2007-2447

PrivEsc

1.1. Resumen Ejecutivo (Executive Summary)

Lame es una máquina Linux de nivel de dificultad principiante (*Easy*) en HackTheBox. Es una de las máquinas clásicas que simula un entorno vulnerable desactualizado.

El vector de ataque principal radica en un servicio **Samba 3.0.20** con una vulnerabilidad de inyección de comandos en el parámetro username map script (**CVE-2007-2447**), lo que permite a un atacante remoto sin autenticación ejecutar comandos arbitrarios directamente como el usuario privilegiado root.

🚩 Vulnerabilidad: Ejecución Remota de Comandos en Samba (Username Map Script)

🚨 CRITICAL

CVE: CVE-2007-2447

CVSS v3.1: 9.8 (Crítico)

Afecta: Samba versiones 3.0.0 a 3.0.25rc3.

Impacto: Compromiso total del sistema sin credenciales previas con privilegios root.

1.2. Reconocimiento y Enumeración

Comenzamos realizando un escaneo de puertos TCP mediante nmap para identificar los servicios expuestos en el objetivo:

```
kali@pentest:~/htb/lame
<MINTED>
```

Puerto	Estado	Servicio	Versión / Detalles
21/tcp	Abierto	FTP	vsftpd 2.3.4 (Anonymous login permitido)
22/tcp	Abierto	SSH	OpenSSH 4.7p1 Debian 8ubuntu1
139/tcp	Abierto	NetBIOS	Samba smbd 3.0.20-Debian
445/tcp	Abierto	SMB	Samba smbd 3.0.20-Debian
3632/tcp	Abierto	Distcc	distccd v1 (GNU Compiler)

Tabla 1: Puertos y servicios descubiertos durante la enumeración inicial.

La versión de Samba identificada es **Samba 3.0.20-Debian**. Esta versión es históricamente conocida por procesar incorrectamente entradas en el comando smbclient al usar credenciales con metacaracteres.

1.3. Explotación (Acceso Inicial & Root)

La vulnerabilidad **CVE-2007-2447** permite enviar una cadena especialmente formateada en el nombre de usuario que contiene caracteres de ejecución por shell: `nohup /bin/sh -c «comando»`.

Método A: Explotación Manual (Vía Python / Netcat)

Preparamos un listener en nuestra máquina atacante:

```
kali@pentest:~  
<MINTED>
```

Ejecutamos el exploit enviando el comando a través del cliente SMB:

```
</> exploit_samba.py  
<MINTED>
```

Explotación vía Metasploit Framework

```
kali@pentest:~  
<MINTED>
```

1.4. Post-Explotación & Evidencias

Una vez obtenida la shell interactiva con privilegios de superusuario `root`, procedemos a estabilizar la terminal y recuperar las banderas del reto:

```
root@lame:~  
<MINTED>
```

🚩 User Flag (makis) ✓ CAPTURADA

```
<MINTED>
```

🚩 Root Flag (Administrador) ✓ CAPTURADA

```
<MINTED>
```

1.5. Remediación y Buenas Prácticas

- **Actualización de Software:** Actualizar Samba a una versión soportada y parcheada (> 3,0,25).
- **Configuración Segura:** En el archivo `/etc/samba/smb.conf`, asegurar que la directiva `username map script` no esté configurada para invocar scripts personalizados sin saneamiento estricto de entradas.
- **Segmentación de Red:** Bloquear el acceso a los puertos SMB (139 y 445) desde redes públicas o no confiables mediante reglas de firewall (`iptables` / `ufw`).